



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

1 - “Introduction to Computer Security”

Gabriele D'Angelo <g.dangelo@unibo.it>

<https://www.unibo.it/sitoweb/g.dangelo/en>



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

1 - “Introduction to Computer Security”

This block of slides **does not refer**
to a specific chapter in the book.

It is a “gentle introduction”

Gabriele D'Angelo <g.dangelo@unibo.it>

<https://www.unibo.it/sitoweb/g.dangelo/en>

A few **basic principles** of computer security:

- principle 1: "*non-existence of secure systems*"
- principle 1 (**corollary**): "*systems complexity*"
- principle 2: "*entities composing a system*"
- principle 3: "*security = knowledge*"

Security of a **cryptosystem** (*i.e., security through obscurity*)

Principle 1: on “Secure Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SECURE SYSTEMS DO NOT EXIST

- **The software is often far from perfect.** It is full of **implementation bugs** and **design errors**. It is the same for **communication protocols**
- **The “unbreakable system” is only a myth.** Just like the impenetrable bank vault or the unsinkable boat (e.g., *RMS Titanic*)

Principle 1: on “Secure Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SECURE SYSTEMS DO NOT EXIST

- The **security level** of a given system is determined by the **amount of time** necessary to break the system, the **amount of money** (or resources) and the **probability of success**

Principle 1: on “Secure Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SECURE SYSTEMS DO NOT EXIST

- The **security level** of a given system is determined by the **amount of time** necessary to break the system, the **amount of money** (or resources) and the **probability of success**

What are we protecting?

Principle 1: on “Secure Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SECURE SYSTEMS DO NOT EXIST

- The **security level** of a given system is determined by the **amount of time** necessary to break the system, the **amount of money** (or resources) and the **probability of success**

What are we protecting? **From who?**

Principle 1: on “Secure Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SECURE SYSTEMS DO NOT EXIST

- The **security level** of a given system is determined by the **amount of time** necessary to break the system, the **amount of money** (or resources) and the **probability of success**

What are we protecting? **From who?** **Why?**

Principle 1: on “Secure Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SECURITY EXIST

- The **security level** is the **amount of time** necessary to compromise the system (given the **resources**) and the **adversary** (or **threat**)
- **Most times** the adversary is **rational**
- **Most times** the adversary has an **economic goal** (that is... \$\$\$)
- This is **not always true** when the adversary is a **government**

What are we protecting? From who? Why?

Principle 1: on “Secure Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- This is an “informal way” for defining a **THREAT MODEL**
- Threat modeling is a structured process used in cybersecurity to identify and analyze potential threats and vulnerabilities in a system or application

DO NOT EXIST

determined by the amount of

the amount of money (or

success

What are we protecting? From **who?** **Why?**

ZERODIUM Payouts for Mobiles*

Up to
\$2,500,000

Up to
\$2,000,000

Up to
\$1,500,000

Up to
\$1,000,000

Up to
\$500,000

Up to
\$200,000

Up to
\$100,000

FCP: Full Chain with Persistence
RCE: Remote Code Execution
LPE: Local Privilege Escalation
SBX: Sandbox Escape or Bypass

■ iOS
■ Android
■ Any OS

3.001 Persistence iOS	2.005 WeChat RCE+LPE iOS/Android	2.006 iMessage RCE+LPE iOS	2.007 FB Messenger RCE+LPE iOS/Android	2.008 Signal RCE+LPE iOS/Android	2.009 Telegram RCE+LPE iOS/Android	2.010 Email App RCE+LPE iOS/Android	4.001 Chrome RCE+LPE Android	4.002 Safari RCE+LPE iOS
5.001 Baseband RCE+LPE iOS/Android		6.001 LPE to Kernel/Root iOS/Android	2.011 Media Files RCE+LPE iOS/Android	2.012 Documents RCE+LPE iOS/Android	4.003 SBX for Chrome Android	4.004 Chrome RCE w/o SBX Android	4.005 SBX for Safari iOS	4.006 Safari RCE w/o SBX iOS
7.001 Code Signing Bypass iOS/Android	5.002 WiFi RCE iOS/Android	5.003 RCE via MitM iOS/Android	6.002 LPE to System Android	8.001 Information Disclosure iOS/Android	8.002 [k]ASLR Bypass iOS/Android	9.001 PIN Bypass Android	9.002 Passcode Bypass iOS	9.003 Touch ID Bypass iOS

1.001
Android FCP Zero Click
Android

1.002
iOS FCP Zero Click
iOS

2.001
WhatsApp RCE+LPE Zero Click
iOS/Android

2.002
iMessage RCE+LPE Zero Click
iOS

2.003
WhatsApp RCE+LPE
iOS/Android

2.004
SMS/MMS RCE+LPE
iOS/Android

* All payouts are subject to change or cancellation without notice. All trademarks are the property of their respective owners.

2019/09 © zerodium.com

ZERODIUM Payouts for Mobiles*

Up to
\$2,500,000

Up to
\$2,000,000

Up to
\$1,500,000

Up to
\$1,000,000

Up to
\$500,000

Up to
\$200,000

Up to
\$100,000

FCP: Full Chain with Persistence
RCE: Remote Code Execution
LPE: Local Privilege Escalation
SBX: Sandbox Escape or Bypass

■ iOS
■ Android
■ Any OS

WhatsApp RCE example:

CVE-2022-36934

3.001 Persistence iOS	WeChat RCE+LPE iOS/Android	iMessage RCE+LPE iOS	FB Messenger RCE+LPE iOS/Android	Signal RCE+LPE iOS/Android	Telegram RCE+LPE iOS/Android	2.010 Email App RCE+LPE iOS/Android	4.001 Chrome RCE+LPE Android	4.002 Safari RCE+LPE iOS
5.001 Baseband RCE+LPE iOS/Android	6.001 LPE to Kernel/Root iOS/Android	2.011 Media Files RCE+LPE iOS/Android	2.012 Documents RCE+LPE iOS/Android	4.003 SBX for Chrome Android	4.004 Chrome RCE w/o SBX Android	4.005 SBX for Safari iOS	4.006 Safari RCE w/o SBX iOS	
7.001 Code Signing Bypass iOS/Android	5.002 WiFi RCE iOS/Android	5.003 RCE via MitM iOS/Android	6.002 LPE to System Android	8.001 Information Disclosure iOS/Android	8.002 [k]ASLR Bypass iOS/Android	9.001 PIN Bypass Android	9.002 Passcode Bypass iOS	9.003 Touch ID Bypass iOS

* All payouts are subject to change or cancellation without notice. All trademarks are the property of their respective owners.

2019/09 © zerodium.com



ZeroDium  @ZeroDium · Jun 1



We're looking for #0day exploits affecting Pidgin on Windows and Linux.

Bounty: \$100,000

Read more: zerodium.com/temporary.html



9



129



213



Gary Kramlich



@rw_grim

Replying to @ZeroDium

This really shows the sad state of funding in open source software.. I managed to find 25k USD last year to work on @impidgin full time, but if you can find a security exploit in my and other's non paid work you can make 4 times as much as I did... 🤔

9:59 PM · Jun 1, 2021 · Twitter Web App

Principle 1: on “Complexity of Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

MORE COMPLEXITY → LESS SECURITY

- (*Empirical rule*) **Increasing the complexity** of a systems leads to an insecure system
- **Linear increase** of complexity means **super-linear increase** of insecurity

Principle 1: on “Complexity of Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

MORE COMPLEXITY → LESS SECURITY

- Do you want to build a “*reasonably secure*” system?

KISS RULE:

- *Keep It Simple and Stupid*
- *Keep It Simple, Stupid*
- *Keep It Short and Stupid*

Principle 1: on “Complexity of Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

MORE COMPLEXITY → LESS SECURITY

- Does this mean that the systems to be secured can **not** be **complex** or **complicated**?

Principle 1: on “Complexity of Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

MORE COMPLEXITY → LESS SECURITY

- Does this mean that the systems to be secured can **not** be **complex** or **complicated**?

NO!

Principle 1: on “Complexity of Systems”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

MORE COMPLEXITY → LESS SECURITY

- The **protection system** must be “*as simple as possible*”. If possible...
“*very simple*”
- **Unnecessary complexity** can lead to {**design, implementation, usage**} errors
- Each **error** is a potential “**vulnerability**”

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

(MOST) SYSTEMS ARE COMPOSED OF 3 TYPES OF ENTITIES

- Software
- Hardware
- Humanware

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SOFTWARE

- It is a critical part of the system with a **large exposed attack surface**
- remember that... **often other parts of the system are “easier to attack”**



- **Many, very complex** programs
- Each program made of **thousands**
or millions of lines of source code
(i.e. *computer instructions*)

- It is a critical part of the system with a **large exposed attack surface**
- remember that... **often other parts of the system are “easier to attack”**

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SOFTWARE

- It is a critical part of the system with a **large exposed attack**

st

That can be **accessed remotely** (i.e. from the **Internet**, from a **wireless network** or from a **user interface**)

- r

attack

the system are “**easier to**

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SOFTWARE

- It is a critical part of the system with a **large exposed attack surface**
- remember ***Everything*** that can be **used by an attacker** to violate the system are “**easier to attack**”

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SOFTWARE

- It is a critical part of the system with a **large exposed attack surface**
- remember that... **often other parts of the system are “easier to attack”**

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Attacking the software often
requires some **technical skills...**

attacking the human in the
system requires skills that are not
about computing

SOFTWARE

system with a **large exposed attack**

- remember that... **often other parts of the system are “easier to attack”**

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

HARDWARE

- All the modern hardware is composed of **hardware AND software** (that is called **firmware**)
- The hardware can be **tampered** by an attacker
- Even the **physical security** of systems and devices (**e.g. to deny unauthorized access**) is hard to guarantee

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

HARDWARE

- All the modern hardware is composed of **hardware AND software** (that is called **firmware**)
- This means that an attacker can **modify the hardware** or **act on the software** (e.g. **flashing a modified firmware**)
- and devices (e.g. to deny

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Definition: “*interfere with (something) in order to cause damage or make unauthorized alterations*”

ARE

composed of **hardware AND software**

- The hardware can be **tampered** by an attacker
- Even the **physical security** of systems and devices (**e.g. to deny unauthorized access**) is hard to guarantee

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

HARDWARE

The “evil maid attack” is an example of unauthorized alteration of personal devices

composed of **hardware AND software**

- The hardware can be **tampered** by an attacker
- Even the **physical security** of systems and devices (**e.g. to deny unauthorized access**) is hard to guarantee

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

HARDWARE

The “evil maid attack” is an example of **unauthorized alteration of personal devices**

A “nice demo”: the time required to flash the tampered firmware is very limited

- The hardware can be **tampered** by a hacker
- Even the **physical security** of systems and devices (**e.g. to deny unauthorized access**) is hard to guarantee

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

HUMANWARE

- The “**human in the loop**” is often the **weakest link** in the system (e.g. **social engineering**)
- For **many reasons**: lack of knowledge, overload, fatigue, bad design, goodwill, lack of attention... stupidity (*in both **users** and **system administrators***)

Principle 2: on “Entities

Definition: “the use of deception to manipulate individuals into divulging confidential or personal information that may be used for fraudulent purposes” (e.g. *phishing emails*)

- The “**human in the loop**” is often the **weakest link** in the system (e.g. **social engineering**)
- For **many reasons**: lack of knowledge, overload, fatigue, bad design, goodwill, lack of attention... stupidity (*in both **users** and **system administrators***)

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

HUMANWARE

- The “**human in the loop**” is **the system** (e.g. **social engineering**)
 - Is “**goodwill**” a **problem**?
 - Yes, when **abused by attackers**
- For **many reasons**: lack of knowledge, overload, fatigue, bad design, goodwill, lack of attention... stupidity (*in both **users** and **system administrators***)

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SECURITY AS A PROCESS

- Securing a system is a [**never ending**] **process** and **not a product**
- **Reasonably secure system** requires **an endless work** on the system and **education**
- The system that today is “secure”, tomorrow will not be. **Everyday news faults are discovered**
- The **lack of updates** leads to **fragile** and **insecure** systems

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

EVEN UPDATING IS NOT EASY...

- Are the updates **available** for all your devices? (e.g. **smartphone**)
- In other words, **is your devices supported? Until when?**

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

EVEN UPDATING IS NOT EASY...

- Are the updates **available** for all your devices? (e.g. **smartphone**)
- In other words, **is your devices supported? Until when?**
- If the updates are available...
 - **what** update to apply? (**All of them...** are you sure of that?)
 - **when** do you apply updates? (During the **night?** In “**production**”?)
 - **why?** (Is that for **security** or to add **new functionalities**?)
 - **how?** (What is the best way to apply the update? **Unattended?**)

Principle 2: on “Entities composing a system”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

EVEN UPDATING IS NOT EASY...

- The **updating process** is always a dangerous operation
 - for example: *fixing bugs can introduce new bugs, instability, side-effects...*
- What we need is a **costs/benefits evaluation**
 - that is **costly** (e.g. *time consuming*)
 - it is often based on **partial information** (i.e. *often there is a lack of detailed information on the updates content*)

Principle 3: on “Security = Knowledge”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

KNOWLEDGE OF THE SYSTEM

- Real security is based on **deep knowledge** (of the system to be protected)
- What are the **effects** of this principle **on software**?
 - **Open Systems** vs. **Closed Systems**
 - **Open Source** vs. **Closed Source**

Principle 3: on “Security = Knowledge”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

KNOWLEDGE OF THE SYSTEM

- Real security is based on **deep** knowledge (the system is not protected)
- What are the **effects** of this principle on software?
 - **Open Systems** vs. **Closed Systems**
 - **Open Source** vs. **Closed Source**

The **specifications** of the system are
OPEN / CLOSED



I really prefer **OPEN** specifications (e.g. for *interoperability*) but this does **not** guarantees that the system is secure (e.g. due to design or implementation faults)

E OF THE SYSTEM

- Real security is based on **deep** protected)

The **specifications** of the system are
OPEN / CLOSED

be

- What are the **effects** of this principle on software?
 - **Open Systems** vs. **Closed Systems**
 - **Open Source** vs. **Closed Source**

Principle 3: on “Security = Knowledge”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

KNOWLEDGE OF THE SYSTEM

- Real security is based on **deep knowledge** (of the system to be protected)
- What are the **effects** of this principle **on software**?
 - **Open Systems** vs. **Closed Systems**
 - **Open Source** vs. **Closed Source**

Principle 3: on “Security = Knowledge”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

KNOWLEDGE OF THE SYSTEM

- Real security is based on **knowledge** (i.e. **source code** protected)
- What are the **effects** of this principle on software?
 - **Open Systems** vs. **Closed Systems**
 - **Open Source** vs. **Closed Source**

The **source code** (i.e. **computer instructions**) used by the programmers to implement the system are

OPEN / CLOSED



Knowledge”

I really prefer **OPEN** Source (e.g. it can be *inspected, verified, validated* etc.) but this does **not** guarantees that the system is secure

GE OF THE SYSTEM

The **source code** (i.e. computer instructions) used by the programmers to implement the system are

OPEN / CLOSED

- Real security based on **data** protected
- What are the **effects** of this principle on software?
 - **Open systems** vs. **Closed Systems**
 - **Open Source** vs. **Closed Source**



I really prefer **OPEN** Source (e.g. it can be *inspected, verified, validated* etc.) but this does **not** guarantees that the system is secure

Even if it is **theoretically possible** (for me) to **check all the code** in a system (e.g. an open source Operating System like GNU/Linux), this is **not practically possible** (since it is made of millions of lines of source code)

- Real security based on protected
- What are the **effect** of this principle on software?
 - **Open systems** vs. **Closed Systems**
 - **Open Source** vs. **Closed Source**

Principle 3: on “Security = Knowledge”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

KNOWLEDGE OF THE SYSTEM

- Real security is based on **knowledge** (of the system to be protected)
- What are the **effects**
 - **Open Systems**
 - **Open Source** v

In most cases it is a matter of

TRUST

Do you prefer to trust a

community (i.e. Open Source) or

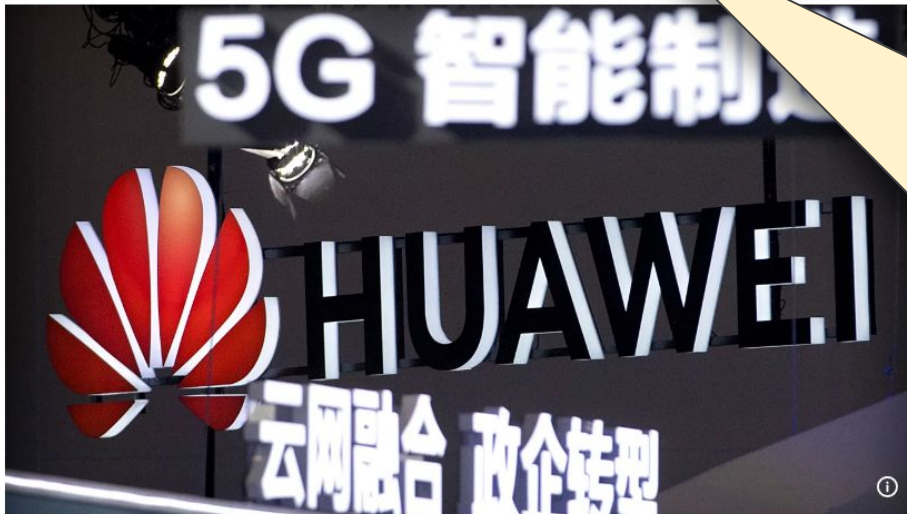
a **company** (i.e. Close Source)

Principle 3: on “Security = Knowledge”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Eleven EU countries took 5G security measures to ban Huawei, ZTE



«Eleven countries [...] have used legal powers to impose **restrictions** on telecom suppliers that are considered high-risk, such as Huawei and ZTE, for 5G network infrastructure, a European Commission spokesperson told Euronews»

Copyright Mark Schiefelbein/Copyright 2018 The AP. All rights reserved

By [Cynthia Kroet](#)

Published on 12/08/2024 - 16:37 GMT+2

Principle 3: on “Security = Knowledge”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

KNOWLEDGE OF THE SYSTEM

- **Users' education** is a form of **knowledge**
- **Investing in education** is good but **not that simple**:
 - education is **costly**
 - **perception of security** [lack of] importance
 - [wrong] **habits** (i.e. “*we have always done it this way*”)
 - **ideological resistance** (i.e. “*information anarchism*”)
 - **cost of security** procedures (vs. “*productive investments*”)

Addendum: “Security of a Cryptosystem”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

KERCKHOFFS'S PRINCIPLE

- “A **cryptosystem** should be secure **even if everything about the system, except the key, is public knowledge**” (1883)

Addendum: “Security of a Cryptosystem”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

KERCKHOFFS'S PRINCIPLE

- “A **cryptosystem** should be secure **even if everything about the system, except the key, is public knowledge**” (1883)

It is a mechanism (i.e. hardware or software) used for **encrypting information** with the aim to preserve **confidentiality**

Addendum: “Security of a Cryptosystem”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

KERCKHOFFS'S PRINCIPLE

- “A **cryptosystem** should be secure **even if everything about the system, except the key, is public knowledge**” (1883)

Addendum: “Security of a Cryptosystem”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

KERCKHOFFS'S PRINCIPLE

- “A **cryptosystem** should be secure **even if everything about the system, except the key, is public knowledge**” (1883)

SHANNON'S REFORMULATION

- “The **enemy knows the system**”

Addendum: “Security of a Cryptosystem”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SECURITY THROUGH OBSCURITY

- Means relying on the **design** or **implementation secrecy** as the main method of providing security

Addendum: “Security of a Cryptosystem”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

SECURITY THROUGH OBSCURITY

- Means relying on the **design** or **implementation secrecy** as the main method of providing security
- The **security through obscurity** is **WRONG**

Addendum: “Security of a Cryptosystem”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

The **security through obscurity** is **WRONG**

- Does this mean that I must **publish all the details about my system internals?**

Addendum: “Security of a Cryptosystem”



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

The **security through obscurity** is **WRONG**

- Does this mean that I must **publish all the details about my system internals**?
- **NO**, it would be very stupid!



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

Gabriele D'Angelo

<g.dangelo@unibo.it>

<https://www.unibo.it/sitoweb/g.dangelo/en>

www.unibo.it

Attributions and Notes



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- These slides are partially based on the work of Prof. **Renzo Davoli**
- **Ludovico Gardenghi** has worked on a previous version of these slides
- I wish to **thank all of them**, **any errors that remain are my sole responsibility**